

acerto.

DOCUMENTO DE AUDITORIA, USO INTERNO

Mapa Funcional Completo do Sistema

alAi

Referência técnica exaustiva com cada etapa, cada condição de ramificação, cada papel envolvido e cada inconsistência encontrada no código-fonte. Cobre Solicitação de Compras, Viagens Acerto, Facilities, NDA e Contratos de Fornecedores, gestão de Contratos, controle de acesso, configurações administrativas, dashboards, IA e notificações.

Sumário

1. Como usar este documento
2. Diagrama completo: máquina de estados
3. Solicitação de Compras, etapa por etapa (16 etapas)
4. Override administrativo (break-glass)
5. Regras transversais, números exatos
6. Chamados simples (Viagens, Facilities, NDA)
7. Contratos
8. Controle de acesso (RBAC)
9. Configurações administrativas
10. Dashboards
11. Recursos de IA: o que decide e o que não decide
12. Notificações: e-mail e Slack
13. Achados para auditoria (16 pontos de atenção)

1. Como usar este documento

Este documento é a contraparte técnica do Manual do Processo (o guia de uso amigável). Aqui, cada afirmação é rastreável ao código-fonte real: arquivo e linha aparecem ao final de cada bloco. Onde uma regra existe apenas como comentário ou intenção documentada, mas não é de fato aplicada no código, isso está sinalizado explicitamente. Não confunda o que está **documentado** com o que está de fato **em vigor**.

A seção 13 (Achados para auditoria) reúne, de forma consolidada, os 16 pontos que mais chamam atenção pra quem for revisar o sistema. Vale começar por ali antes de entrar no detalhamento etapa por etapa.

Legenda de severidade usada na seção 13

R: regra não aplicada. Documentada ou esperada, mas não é de fato imposta pelo código.

D: inconsistência de documentação ou mensagem. O comportamento real diverge do texto exibido ou comentado.

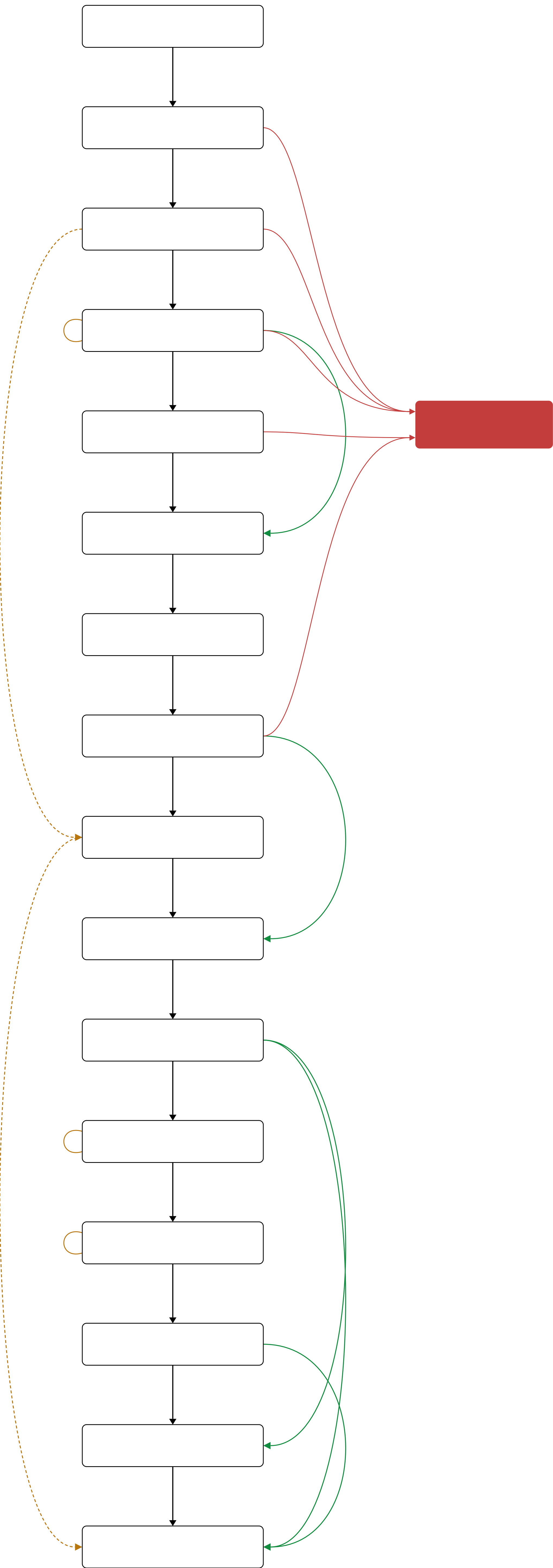
A: lacuna de superfície administrativa. Falta tela ou rota pra operar algo que já existe no modelo de dados.

S: ponto de atenção de segurança ou robustez.

Diagrama completo: Solicitação de Compras

Máquina de estados completa. 16 etapas, todos os desvios condicionais, laços e atalhos de cancelamento. Fonte: `src/lib/workflow.ts` e as rotas de API de cada etapa.

— Fluxo padrão — Ramificação (pula etapas) - - - Atalho de cancelamento / laço — Vai para Cancelado



Não representado neste diagrama (ver seção "Override administrativo"): um ADMIN pode mover uma solicitação para qualquer etapa, em qualquer direção, sem revalidar nenhuma regra. É um mecanismo de exceção, fora do fluxo normal.

3. Solicitação de Compras, etapa por etapa

Nem toda solicitação passa por todas as 16 etapas. O desvio exato depende do tipo de demanda, do valor estimado e das aprovações. Abaixo, cada etapa com quem age, o que dispara a entrada, todos os caminhos de saída e os efeitos colaterais reais (e-mail, Slack, registros criados).

1. Solicitação de Compra

Solicitante

Disparo: Envio do formulário Nova Solicitação. O código é gerado como PC-{ano}-{sequência}.

> Avança automaticamente para Aprovação do Gestor assim que criada. Esta etapa é transitória, nunca fica parada aqui.

Efeitos colaterais: Notificação de confirmação de recebimento por e-mail ao solicitante. Slack DM a todos os gestores do centro de custo, não só o principal.

`src/app/api/requests/route.ts` (POST)

2. Aprovação do Gestor

Gestor do Centro de Custo

Disparo: Automática, na criação da solicitação.

> Aprovado: segue para Homologação e Triagem.

> Reprovado (exige justificativa): vai para Cancelado.

> Um ADMIN pode decidir em nome do gestor a qualquer momento, sem teto de valor.

Efeitos colaterais: E-mail de reprovação. Não há e-mail de aprovação nesta etapa, uma assimetria (ver achado 9).

`src/app/api/requests/[id]/aprovacao-gestor/route.ts`

3. Homologação e Triagem

Comprador

Disparo: Aprovação do gestor concedida.

> Ação Devolver: permanece em Triagem, com um comentário registrado, sem mudança de etapa.

> Tipo de demanda igual a Cancelamento: vai direto para Jurídico, pulando Orçamento, Cotação, Aprovação e Pedido de Compra.

> Nos demais casos: segue para Validação Orçamentária, depois de calcular a faixa de risco (lane) e o sinalizador de fracionamento.

Efeitos colaterais: Exige valor estimado antes de prosseguir, se ainda não informado. E-mail de atualização de etapa ao solicitante. Se fracionamento é detectado, cria um registro de notificação, mas não dispara e-mail ou Slack de fato (ver achado 3).

`src/app/api/requests/[id]/triagem/route.ts`

4. Validação Orçamentária

Comprador. Exceção: Coordenação ou Gerente F&NC

Disparo: Saída da Triagem.

> Orçamento OK e Ferramenta Nova: segue para Due Diligence.

> Orçamento OK e qualquer outro tipo, inclusive Upgrade ou Downgrade: segue para Cotação.

> Sem orçamento: entra em exceção orçamentária, permanece na própria etapa até uma decisão.

> Exceção reprovada: vai para Cancelado. Exceção aprovada: segue a mesma lógica de roteamento acima.

Efeitos colaterais: E-mail de atualização de etapa só no caminho direto com orçamento OK. A exceção aprovada não dispara este e-mail. Anexa automaticamente o comprovante de Orçamento Extra à exceção, quando existe.

`src/app/api/requests/[id]/validacao-orcamentaria/route.ts`

5. Due Diligence (Privacidade)

Privacidade

Disparo: Ferramenta nova aprovada no orçamento.

- > Aprovado: segue para Cotação.
- > Reprovado: vai para Cancelado, com motivo padrão "Reprovado em Due Diligence" se não informado.

Efeitos colaterais: E-mail de atualização de etapa, na aprovação, ou de reprovação.

`src/app/api/requests/[id]/due-diligence/route.ts`

6. Cotação

Comprador

Disparo: Orçamento validado, com ou sem due diligence.

- > Mínimo de propostas atingido (1 se até R\$2.500, 3 acima disso): segue para Mapa de Cotação.

Efeitos colaterais: Uma chamada por fornecedor cotado. E-mail de atualização de etapa ao avançar.

`src/app/api/requests/[id]/cotacao/route.ts`

7. Mapa de Cotação

Comprador

Disparo: Número mínimo de cotações atingido.

- > Fornecedor vencedor selecionado: segue para Aprovação.

Efeitos colaterais: E-mail de atualização de etapa.

`src/app/api/requests/[id]/mapa-cotacao/route.ts`

8. Aprovação

Aprovador (pool por alçada)

Disparo: Fornecedor selecionado no Mapa de Cotação.

- > Exige declaração de conflito de interesse, sem conflito, antes de criar a aprovação.
- > Nível 1, até R\$50 mil: 1 aprovador decide. Níveis 2 e 3, acima disso: exige 2 aprovadores distintos, uma dupla checagem. Se algum ainda estiver pendente, a solicitação não avança.
- > Aprovado, exigindo contrato: segue para Jurídico. Aprovado sem contrato: segue para Pedido de Compra.
- > Reprovado por qualquer aprovador do lote: vai para Cancelado, mesmo que outro já tenha aprovado.

Efeitos colaterais: Prazo de decisão de 3 dias corridos, apesar do nome da constante dizer dias úteis (ver achado 5). E-mail de aprovado ou reprovado. Aviso por Slack quando alguém decide em nome de outro (personificação).

`src/app/api/requests/[id]/aprovacao/route.ts`

9. Jurídico

Jurídico

Disparo: Aprovação concluída com exigência de contrato, ou atalho de Cancelamento vindo da Triagem.

- > Contrato assinado e tipo Cancelamento: vai direto para Concluído, pulando Pedido de Compra.
- > Contrato assinado e qualquer outro tipo: segue para Pedido de Compra.
- > Ainda não assinado: permanece em Jurídico.

Efeitos colaterais: E-mail de atualização de etapa.

`src/app/api/requests/[id]/juridico/route.ts`

10. Pedido de Compra

Comprador

Disparo: Revisão jurídica concluída, ou aprovação sem exigência de contrato.

- > Emissão do PDF oficial: segue para Aguardando Entrega ou Conclusão.

Efeitos colaterais: Gera e salva o PDF do Pedido de Compra no sistema de arquivos local. E-mail com o link do PDF.

`src/app/api/requests/[id]/pedido-compra/route.tsx`

11. Aguardando Entrega/Conclusão

Comprador

Disparo: Pedido de Compra emitido.

- > Exige medição: segue para Medição, que tem prioridade sobre mapeamento quando ambos são verdadeiros.
- > Sem medição, mas gera contrato: segue para Mapeamento de Contrato.
- > Sem medição e sem contrato: vai para Concluído.

Efeitos colaterais: E-mail de atualização de etapa.

`src/app/api/requests/[id]/aguardando-entrega/route.ts`

12. Medição e Aprovação Financeira

Comprador

Disparo: Compra exige medição, por exemplo serviços recorrentes ou obras.

- > Aprovado tecnicamente: segue para Validação Fiscal.
- > Reprovado ou pendente: permanece em Medição. Não há caminho de cancelamento aqui.

Efeitos colaterais: E-mail de atualização de etapa ao avançar.

`src/app/api/requests/[id]/medicao/route.ts`

13. Validação Fiscal

Fiscal

Disparo: Medição aprovada.

- > Documento aprovado: segue para Tesouraria.
- > Documento reprovado: permanece em Validação Fiscal. Não há caminho de cancelamento.

Efeitos colaterais: E-mail de atualização de etapa ao avançar.

`src/app/api/requests/[id]/fiscal/route.ts`

14. Tesouraria (Pagamento)

Tesouraria

Disparo: Documento fiscal aprovado.

- > ERP confirma o pagamento e gera contrato: segue para Mapeamento de Contrato.
- > ERP confirma o pagamento, sem contrato: vai para Concluído.

Efeitos colaterais: E-mail de atualização de etapa.

`src/app/api/requests/[id]/tesouraria/route.ts`

15. Mapeamento de Contrato

Comprador

Disparo: Pagamento confirmado, ou saída direta de Aguardando Entrega, quando a compra gera contrato vigente.

- > Contrato cadastrado: vai para Concluído.

Efeitos colaterais: Cria o registro de Contrato, que alimenta a área de Contratos. E-mail de atualização de etapa.

`src/app/api/requests/[id]/mapeamento-contrato/route.ts`

16. Concluído

Nenhum

Disparo: Fim do fluxo, por qualquer um dos caminhos acima.

- > Terminal. A única ação permitida é o registro de Avaliação (NPS de 0 a 10), que é só informativo e não afeta mais nada.

`src/app/api/requests/[id]/avaliacao/route.ts`

Cancelado, terminal

Nenhuma ação adicional definida. Alcançável a partir de Aprovação do Gestor, Triagem, Validação Orçamentária (exceção reprovada), Due Diligence e Aprovação.

4. Override administrativo (break-glass)

Existe um mecanismo de exceção total. Um ADMIN pode mover qualquer solicitação para qualquer etapa do enum, pra frente ou pra trás, sem que nenhuma regra de negócio da etapa de destino seja reverificada e sem reenviar nenhum efeito colateral (e-mail ou Slack) da etapa. Fica registrado no histórico com um comentário que distingue se foi avanço ou retrocesso, sem validações da etapa.

Ponto de atenção

O status da solicitação (Aberto, Cancelado, Concluído) é recalculado de forma simplificada, só com base na etapa de destino. Mover uma solicitação Cancelada ou Concluída de volta pra qualquer etapa intermediária a reabre automaticamente como Aberto, mesmo que as condições originais de cancelamento ou conclusão nunca tenham sido revertidas de fato.

`src/app/api/requests/[id]/stage-override/route.ts`

5. Regras transversais, números exatos

Faixas de risco (lanes)

Faixa	Condição exata
Fast	Valor até R\$5 mil, fornecedor já homologado e risco baixo.
Standard	Dado pessoal ou ferramenta nova, sem ultrapassar R\$500 mil, ou qualquer caso que não se enquadre em Fast nem Strategic.
Strategic	Valor acima de R\$500 mil, ou fornecedor de risco alto, ou (dado pessoal ou ferramenta nova) acima de R\$500 mil.

Alçadas de Aprovação (etapa Aprovação)

Nível	Valor	Aprovadores exigidos
1	Até R\$50 mil	1 aprovador do pool configurado para o nível
2	Até R\$500 mil	2 aprovadores distintos, dupla checagem
3	Acima de R\$500 mil	2 aprovadores distintos, dupla checagem. Não há papel de CEO no código

Exceção Orçamentária (etapa Validação Orçamentária, quando não há saldo)

Nível	Valor	Quem decide
1	Até R\$5 mil	Coordenação
2	R\$5 mil a R\$25 mil	Gerente F&NC
3	Acima de R\$25 mil	Gerente F&NC. Sem CEO

Outras regras com número exato

- **Cotações mínimas:** 1 proposta até R\$2.500. 3 propostas acima disso.
- **Anti-fracionamento:** soma o valor de todas as solicitações do mesmo fornecedor nos últimos 12 meses e sinaliza a Controladoria se a soma ultrapassar uma alçada que o valor individual sozinho não atingiria. Apenas detecta e sinaliza, não bloqueia a solicitação.
- **Personificação (comprador):** só permitida no Nível 1 de alçada, até R\$50 mil. Um ADMIN personifica em qualquer nível e etapa, sem teto.
- **Conflito de interesse:** obrigatório declarar (sem conflito) antes de criar qualquer Aprovação. Bloqueia se houver conflito declarado.
- **Escalonamento:** 3 dias sem decisão do aprovador dispara um lembrete automático por Slack ao aprovador e à Controladoria, via rotina agendada. Apenas avisa, nunca decide ou pula a etapa sozinho.
- **Orçamento Extra:** a opção Orçamento Extra no formulário exige, na interface, anexar o comprovante de validação do FP&A antes de enviar. Essa obrigatoriedade não é reforçada na API (ver achado 8).
- **Alinhamento com a liderança (Sim/Não):** campo obrigatório no formulário, mas puramente informativo. Nenhuma etapa ou regra usa esse valor para decidir algo. Só aparece no histórico e gera um aviso ao solicitante quando marca Não.

6. Chamados simples (Viagens, Facilities, NDA)

Fluxo enxuto e idêntico nas três categorias. A única diferença real são os campos extras específicos de Cadastros, Contratos de Fornecedores e NDA, ligados a fornecedor ou contrato. Não passa pelas alçadas, orçamento ou aprovações da Solicitação de Compras: é, de propósito, fora desse processo.

- **Abertura:** qualquer pessoa com e-mail @acerto.com.br, sem exigir vínculo com usuário cadastrado. Nome e e-mail em texto livre.
- **Status:** Aberto, Em Andamento, Concluído. Só quem tem acesso ao quadro (Admin, Comprador, Aprovador ou Controlador) muda o status.
- **Mensagens:** quem tem acesso ao quadro ou o próprio solicitante, validado por e-mail, pode responder. Toda mensagem nova dispara e-mail ao solicitante, de qualquer autor.
- **Anexos:** o endpoint de anexo aceita qualquer chamada sem checar se quem está anexando é o solicitante ou tem acesso ao quadro (ver achado 14).

7. Contratos

- **Duas origens:** gerado automaticamente ao concluir Mapeamento de Contrato numa solicitação, ou importado avulso e legado via planilha, sem vínculo com solicitação.
- **Cancelamento:** exige confirmação explícita de que a Tesouraria foi avisada antes de cancelar, uma proteção contra pagamento recorrente de um contrato já cancelado. Notifica a Tesouraria por e-mail e Slack.
- **Alerta de renovação:** rotina agendada avisa 3 meses antes do vencimento, por e-mail e Slack ao gestor do contrato. O dashboard também mostra, à parte, contratos vencendo em 60, 30 ou 10 dias.
- **Importação em massa:** planilha com modelo fixo. Linhas com erro são reportadas individualmente, sem invalidar o lote inteiro. Exige que o e-mail do gestor já exista como usuário cadastrado.

8. Controle de acesso (RBAC)

- **11 papéis:** Solicitante, Comprador, Aprovador, Jurídico, Tesouraria, Controladoria, Privacidade, Fiscal, Admin, Coordenação, Gerente F&NC. Não existe papel de CEO.
- **Acesso ao quadro (Solicitações, Contratos, Dashboards):** Admin, Comprador, Aprovador ou Controladoria. Solicitante sozinho não vê.
- **Login:** Google restrito a @acerto.com.br. O primeiro acesso cria o usuário automaticamente só com o papel Solicitante. Qualquer papel adicional só é concedido manualmente por um Admin.
- **Desativação:** soft-delete. O usuário fica inativo e todo o histórico é preservado. Nada é apagado de fato.
- **Admin é bypass universal:** qualquer verificação de papel numa ação de etapa passa automaticamente para quem tem o papel Admin.

9. Configurações administrativas

- **Centros de Custo:** criação, gestores (múltiplos por centro), ativar ou desativar. Trocar os gestores migra automaticamente as aprovações ainda pendentes desse centro para o novo gestor principal. Decisões já tomadas ficam intocadas.
- **Alçadas de Aprovação:** pool de aprovadores por nível (1, 2 ou 3). Trocar o pool migra aprovações pendentes daquele nível para o novo aprovador principal, e nunca mexe em aprovações já decididas.
- **Por Aprovador:** visão inversa, escolhe, por pessoa aprovadora, quais centros de custo ela pode decidir. É a mesma relação de dados de Centros de Custo, só outro ângulo de tela.
- **Acessos:** gerencia só 5 dos 11 papéis (Admin, Comprador, Solicitante, Aprovador e Controladoria). Os outros 6 (Tesouraria, Fiscal, Jurídico, Privacidade, Coordenação, Gerente F&NC) só aparecem pra filtro, sem botão de conceder ou revogar (ver achado 13).

10. Dashboards

Uma única função central calcula tudo que aparece na tela, na exportação Excel e na exportação PDF, garantindo que o exportado é exatamente o que está na tela.

- KPIs com variação em relação ao período anterior: gasto total, número de solicitações, número de pedidos de compra, ciclo médio, economia total e percentual, percentual de SLA cumprido, fornecedores ativos.
- Evolução mensal (12 meses), ranking de fornecedores (nota de confiabilidade de 0 a 100, documentada como proxy interno, não uma certificação de mercado), ranking de compradores, funil por etapa, histograma de tempo de ciclo, mapa de sazonalidade.
- Mapa de risco: concentração num único fornecedor, urgências críticas, compras sem contrato mapeado, atrasos de SLA, fornecedores de risco alto, fracionamentos sinalizados, exceções orçamentárias pendentes, decisões personificadas.
- Alertas inteligentes, todos calculados em cima de dado real, sem número inventado: contratos a vencer, economia abaixo da meta (só dispara se a meta estiver configurada), SLA de um comprador muito abaixo da média do time, fornecedor sem avaliação NPS, concentração de fornecedor acima de 40%.

11. Recursos de IA: o que decide e o que não decide

Confirmado: nenhuma etapa do fluxo usa resposta de IA como condição de avanço. Todo uso é assistivo: sugere, resume, aponta risco. A decisão final é sempre de uma pessoa.

- **Sugerir com IA (Nova Solicitação):** classifica o texto livre em tipo de demanda e prioridade, sinaliza provável Due Diligence. Nada é preenchido sem clique, tudo continua editável.
- **Painel de insight por etapa:** Triagem, Due Diligence, Cotação e Mapa de Cotação (com síntese comparativa a partir de 3 ou mais cotações), Jurídico, Aprovação (resumo executivo) e Mapeamento de Contrato. Cada um com aviso explícito de que não substitui a análise humana.
- **Histórico de fornecedor (12 meses):** não é IA. É uma consulta SQL determinística que alimenta o alerta de fracionamento.
- **Chaves de API:** cada pessoa usa sua própria chave, Anthropic ou Gemini, criptografada em repouso. Nunca uma chave única do sistema inteiro.

12. Notificações: e-mail e Slack

Toda tentativa de notificação grava um registro, de sucesso ou de falha. Nenhuma etapa do workflow é bloqueada por falha de e-mail ou Slack.

- **E-mails:** confirmação de recebimento, atualização de etapa (genérico, dispara na maioria das transições), reprovado, aprovado, pedido de compra gerado, chamado aberto, nova mensagem em chamado, alerta de renovação de contrato.
- **Ausência notável:** não existe e-mail de aprovação na etapa Aprovação do Gestor, só de reprovação.
- **Slack:** aviso de nova solicitação a todos os gestores do centro de custo, disclosure de decisão personificada, lembrete de escalonamento ao aprovador e à Controladoria, alerta de renovação de contrato, aviso de cancelamento de contrato à Tesouraria.

13. Achados para auditoria (16 pontos de atenção)

Consolidação do que este levantamento encontrou como inconsistência, lacuna ou regra não aplicada. Cada achado traz agora a situação depois da rodada de correções de 19/08/2026. Ver legenda de severidade na página 2.

O que foi corrigido além desta lista

A maior parte do trabalho de correção não saiu destes 16 pontos: veio da revisão de segurança, que corria em paralelo e não estava neste documento. Registrado aqui para o número de achados resolvidos abaixo não dar a impressão errada de que pouco mudou.

Segurança

A decisão de aprovação passou a exigir que quem chama seja o aprovador designado: antes, omitir um campo do corpo pulava toda a checagem e permitia aprovar qualquer valor sem papel e sem rastro. As rotas de API passaram a ficar sob o middleware, que não as cobria: 30 de 57 não tinham checagem própria. A flag de bypass de autenticação passou a ser ignorada em produção e documentada. O webhook do Slack deixou de aceitar evento quando o segredo falta. A importação de contratos passou a exigir sessão de administrador. Desativar uma pessoa passou a encerrar a sessão dela.

Integridade de dados

O código sequencial das solicitações era gerado contando linhas, o que colidia sob concorrência: medido, 20 criações simultâneas produziam 20 códigos e 1 valor distinto. As 15 rotas de etapa passaram a gravar a mudança e o registro de auditoria na mesma transação. O CNPJ passou a ser normalizado, o que fazia o controle anti-fracionamento somar zero e nunca sinalizar. A importação de contratos deixou de duplicar a carteira. Foram criados 45 índices, onde não havia nenhum.

Operação e uso

Passaram a existir telas de erro, log estruturado e conferência de variáveis de ambiente na inicialização. Os tokens de máquina deixaram de aceitar a string literal que a ausência da variável produzia. Uploads ganharam limite de tipo e tamanho. Os PDFs de Pedido de Compra saíram da pasta pública, onde eram enumeráveis. As ações de etapa e os painéis administrativos passaram a dar retorno visível, no sucesso e na falha.

- 1 SLA por etapa é só cosmético** **RESOLVIDO**
Os campos de prazo por etapa (Corporativo, Tecnologia e Revenue) só existem em 8 das 16 etapas e nunca são lidos em código. O único prazo de fato aplicado é o prazo geral, calculado uma vez na criação da solicitação.
Correção: por decisão do time, esses tempos são referência de expectativa, não prazo cobrado. Deixaram de ser dado morto: a tela da solicitação passou a mostrar o tempo esperado da etapa atual e a previsão de conclusão, com o aviso de que não travam nada. Os tempos das etapas de execução foram definidos com o time (Mapa de Cotação, Pedido de Compra, Medição, Fiscal, Tesouraria e Mapeamento de Contrato); Solicitação, Aguardando Entrega e os estados finais seguem sem tempo de propósito. Manual corrigido.
- 2 Grafo de transições válidas não é reforçado em produção** **RESOLVIDO**
A função que valida se uma transição de etapa é permitida existe só para os testes automatizados. Cada rota de API faz sua própria checagem isolada da etapa atual, sem consultar esse grafo.
Correção: as 15 rotas de etapa passaram a usar um helper transacional que consulta o grafo antes de gravar.
- 3 Alerta de fracionamento não avisa ninguém de verdade** **RESOLVIDO**
Quando o sistema detecta risco de fracionamento na Triagem, ele grava um registro de notificação no banco. Diferente de todo outro alerta do sistema, não dispara e-mail nem Slack de fato. A Controladoria não é realmente avisada.
Correção: a Triagem passou a disparar e-mail e mensagem de Slack para a Controladoria quando sinaliza o risco, com a alçada isolada e a somada dos últimos 12 meses. O registro de notificação que afirmava um envio inexistente saiu: quem grava agora é o próprio envio, com ENVIADO ou FALHA conforme o resultado real.
- 4 Triagem básica de fornecedor é código morto** **PARCIAL**
Existe uma função pronta e testada para exigir triagem básica de fornecedor novo (CNPJ ativo, listas restritivas). Ela nunca é chamada por nenhuma rota real. A regra está escrita, mas não está em vigor.
Correção: por decisão do time, a triagem sinaliza mas não bloqueia: a solicitação avisa quando o fornecedor escolhido está pendente ou reprovado, e há um campo de anexo opcional para a evidência da verificação, que o comprador faz fora do sistema. O bloqueio antes do Pedido de Compra fica para depois.

- 5 Escalonamento de 3 dias é corrido, não útil** **RESOLVIDO**
- O prazo de decisão do aprovador antes do lembrete automático é chamado de dias úteis no código, mas a conta real não pula fim de semana. São 3 dias corridos de fato.
- Correção: o prazo passou a ser calculado por uma função que pula sábado e domingo, então uma aprovação aberta na quinta vence na terça, não no domingo. Feriado ainda não é considerado, por falta de calendário de feriados no sistema.
- 6 Mensagem de lembrete pode divergir do prazo real** **RESOLVIDO**
- O texto do lembrete de escalonamento lê uma variável de ambiente diferente da que de fato define o prazo. Mudar uma não muda a outra, o que pode deixar a mensagem incoerente com o prazo real aplicado.
- Correção: o texto do lembrete passou a ler a mesma constante que calcula o prazo, e a variável de ambiente duplicada foi removida, então mensagem e prazo não têm mais como divergir.
- 7 Comentários do schema ainda citam o papel de CEO** **RESOLVIDO**
- O papel de CEO foi removido do sistema e não existe mais no cadastro de papéis. Dois comentários no modelo de dados ainda descrevem a alçada de nível 3 como envolvendo o CEO. É desatualização de documentação interna.
- Correção: os dois comentários do modelo de dados foram corrigidos, e uma terceira menção que sobrou no cálculo da alçada, encontrada só na verificação posterior, também.
- 8 Anexo obrigatório do Orçamento Extra só é exigido na tela** **RESOLVIDO**
- O formulário impede o envio sem o anexo de validação do FP&A quando Orçamento Extra é escolhido. A API que de fato cria a solicitação aceita a mesma opção sem checar se o anexo existe. Uma chamada direta à API contornaria essa exigência.
- Correção: fechado em três pontos: os dois ramos da Validação Orçamentária e a Aprovação do Gestor. Um agente adversarial ainda encontrou o caminho mais fácil de todos, que era o controle inteiro depender de um booleano declarado pelo próprio solicitante na criação: bastava digitar qualquer coisa no campo Linha do Orçamento para desligá-lo nos três pontos de uma vez. Hoje abrir a exceção por indisponibilidade de orçamento marca a solicitação como extra-orçamentária, corrigindo o registro, e APROVAR a exceção exige o comprovante independente do que foi marcado na abertura. Reprovar segue livre, senão a solicitação fica presa esperando um documento que pode nunca chegar. O que sobra: a criação ainda aceita Orçamento Extra sem anexo.
- 9 Aprovação do gestor não notifica o lado positivo** **RESOLVIDO**
- Ao contrário de toda outra etapa, quando o gestor do centro de custo aprova a solicitação, nenhum e-mail é enviado ao solicitante. Só a reprovação gera notificação.
- Correção: o caminho aprovado deixou de ser silencioso e passou a usar o mesmo aviso das outras etapas, informando ao solicitante que a compra seguiu para Homologação e Triagem.
- 10 Alerta de renovação de contrato não garante cadência semanal** **RESOLVIDO**
- O alerta de renovação disparava em toda chamada da rota, sem olhar o histórico de envios. Duas execuções no mesmo dia mandavam dois avisos iguais, e a periodicidade prometida dependia inteiramente de como o agendador externo estivesse configurado, sem configuração versionada no repositório.
- Correção: a cadência passou a ser decidida pela própria rota, a partir do último alerta registrado para o contrato: só sai aviso novo se o anterior tiver mais de uma semana. Sem campo novo no banco, usando o histórico que já existia. Chamada duas vezes no mesmo dia, a rota avisa uma vez só; e o agendador passa a ser configurado para rodar todo dia, de modo que um dia perdido é recuperado no dia seguinte. A janela tem meia jornada de folga, para que um atraso de minutos no agendador não pule a semana inteira. O manual passou a descrever a regra por extenso.
- 11 Registro de alerta de contrato subestima o canal usado** **RESOLVIDO**
- O log de alerta de renovação sempre grava o canal como e-mail, mesmo nas execuções em que um Slack também foi enviado. O registro não reflete os dois canais reais usados.
- Correção: o canal gravado passou a refletir os dois meios, e a tela do contrato traduz o valor.
- 12 Link de pré-preenchimento a partir de contrato não funciona** **RESOLVIDO**
- O e-mail de alerta de renovação leva a um link que promete pré-preencher uma nova solicitação a partir do contrato vencendo. Esse parâmetro não é lido em lugar nenhum do formulário. O link abre um formulário em branco.
- Correção: o formulário passou a ler o contrato de origem e abrir preenchido com fornecedor, tipo de demanda, descrição, diretoria e centro de custo. A primeira correção resolvia só metade: quem clicava no e-mail sem sessão viva era mandado ao login e voltava sem o parâmetro, caindo no mesmo formulário em branco, porque o redirecionamento descartava a query. Corrigido depois, com teste.

13 6 dos 11 papéis não têm tela de gestão **RESOLVIDO**

A página de Acessos só concede ou revoga 5 papéis. Os outros 6 (Tesouraria, Fiscal, Jurídico, Privacidade, Coordenação, Gerente F&NC) têm poder real sobre dinheiro ou aspectos jurídicos, mas só aparecem como filtro. Não existe caminho pela interface pra tornar alguém, por exemplo, Fiscal ou Tesouraria. Só via banco de dados diretamente.

Correção: os seis papéis de etapa ganharam botão próprio na tela de acessos, e a rota que grava passou a aceitar os 11, na mesma tabela que a checagem de permissão consulta. Conceder Fiscal ou Tesouraria não exige mais mexer no banco.

14 Anexo de chamado sem checagem de quem está anexando **RESOLVIDO**

Ao contrário do endpoint de mensagens, que confere se quem está agindo é o solicitante ou tem acesso ao quadro, o endpoint de anexar arquivo a um chamado aceita qualquer chamada que souber o identificador do chamado, sem checar identidade.

Correção: a checagem de vínculo que faltava foi feita em 20/08: as duas rotas de anexo de chamado passaram a exigir que quem chama seja o dono do chamado ou tenha acesso ao quadro, e a identidade de quem anexa vem da sessão em vez do corpo da requisição.

15 Override administrativo pode reabrir o que já foi encerrado **PARCIAL**

O mecanismo de exceção, mover uma solicitação pra qualquer etapa sem revalidar nada, recalcula o status de forma simplificada. Mover uma solicitação Cancelada ou Concluída de volta pra qualquer etapa intermediária a marca automaticamente como Aberta de novo, mesmo sem reverter de fato a razão original do cancelamento ou conclusão.

Correção: a mudança de etapa e o registro de auditoria passaram a ser atômicos. O recálculo simplificado de status segue como está.

16 Chave de criptografia de IA é única e compartilhada **EM ABERTO**

As chaves de API de IA de cada pessoa são guardadas criptografadas no banco, mas a chave que criptografa todas elas vem de uma única variável de ambiente. Não é um cofre de segredos gerenciado, nem uma chave por usuário. O próprio código já sinaliza isso como algo a revisar antes de produção.

Encontrado depois: esta auditoria olhou escrita e não olhou leitura

Os 16 achados acima saíram de uma leitura concentrada em quem pode ALTERAR o sistema. No dia seguinte, um inventário das 74 rotas mostrou que o outro lado nunca tinha sido olhado: 37 delas não exigiam nada além de uma sessão qualquer, e 16 eram de risco alto. Entre elas, o download de qualquer anexo, a carteira inteira de contratos e a exportação completa da base em Excel.

Junto veio um vazamento que ninguém decidiu: 24 rotas devolviam as chaves de IA pessoais no corpo da resposta. A causa era sempre a mesma, um include escrito para pegar o nome de quem pediu e o banco entregando todas as colunas junto. Um único ponto, o helper de avanço de etapa, respondia por 14 delas.

A alçada, que é o controle financeiro central, tinha dois furos que não eram de autenticação e por isso escaparam desta auditoria inteira: o nível saía do valor estimado na Triagem e nunca era reconferido contra a cotação vencedora, e a tabela de aprovadores estava vazia nos três níveis, o que fazia do caminho manual o único existente. Na prática, o comprador escolhia quem aprova a própria compra.

A lição de método vale mais que os itens. Quase tudo isso foi encontrado por um agente adversarial atacando trabalho recém-concluído, não pela leitura que o produziu, e vários furos estavam no código escrito horas antes no mesmo dia, incluindo comentários que afirmavam uma cobertura que o código não tinha. Existe agora uma trava automatizada que reprova rota nova sem decisão de acesso, para o próximo esquecimento falhar sozinho em vez de esperar a próxima auditoria.

Este documento descreve o código, não o ambiente

Um achado marcado como resolvido significa que o código mudou e que existe teste cobrindo. Não significa que o sistema está configurado nem que foi exercido. Em 20/08/2026 a tabela de aprovadores por alçada estava vazia, o caminho autenticado nunca tinha sido percorrido por uma pessoa (toda verificação em navegador rodou com o desvio de autenticação de desenvolvimento ligado, e os testes simulam a sessão), e não existia deploy nem integração contínua. Ler os selos acima como atestado de prontidão para produção seria erro de interpretação.